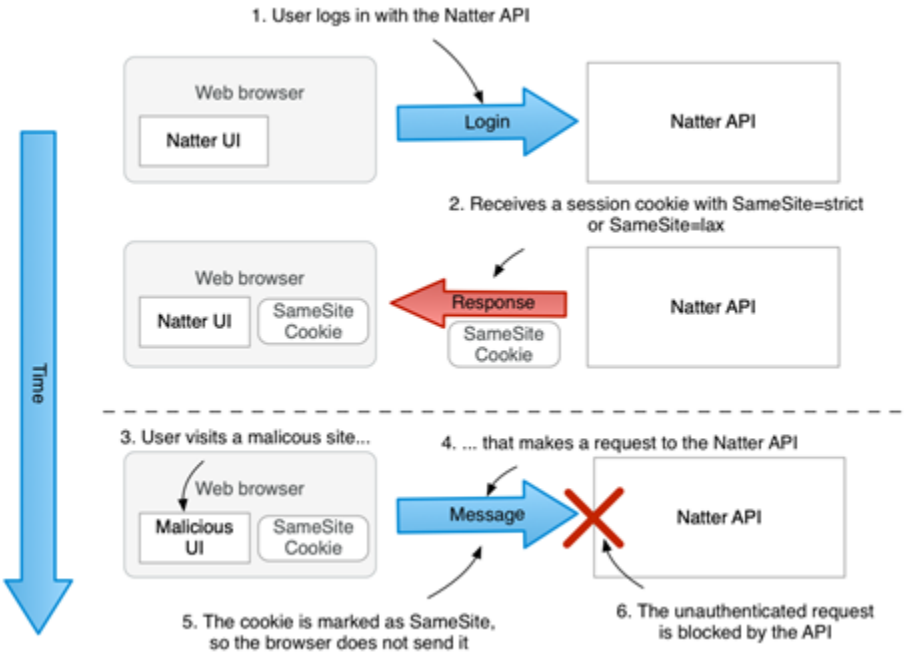


Figure 4.10 When a cookie is marked as SameSite=strict or SameSite=lax, then the browser will only send it on requests that originate from the same domain that set the cookie. This prevents CSRF attacks as cross-domain requests will not have a session cookie and so will be rejected by the API.

To mark a cookie as SameSite, you can add either `SameSite=lax` or `SameSite=strict` on the Set-Cookie header, just like marking a cookie as Secure or HttpOnly (section 4.3.2). The difference between the two modes is subtle. In strict mode, cookies will not be sent on any cross-site request including when a user just clicks on a link from one site to another. This can be quite surprising behavior that can break traditional websites. To get around this, lax mode allows cookies to be sent when a user directly clicks on a link but will still block cookies on most other cross-site requests. Strict mode should be preferred if you can design